

Strengthening Incident Response and Business Continuity through exercising

From plan to practice



The reality of modern threats

From ransomware and data breaches to third-party compromises and insider threats, organisations of all sizes are operating in an increasingly volatile digital environment. While many businesses have documented incident response (IR) and business continuity plans (BCPs), too few have tested them under real-world conditions. This leaves critical gaps in readiness when the pressure is on – especially in aligning technical response actions with broader incident management, which encompasses strategic decision-making, stakeholder communication, and leadership.

When a crisis hits, everything must move quickly and decision-making must be swift, coordinated, and informed. That's only possible when plans have been stress-tested with the right stakeholders across technical and business functions including legal, finance, and communications teams at all levels of command. Without regular testing, even the most comprehensive plans can fail; leading to confusion, delays, reputational damage, and financial loss.

This white paper explores why incident response and business continuity plan exercising is essential for digital resilience. We look at the key benefits, common pitfalls, and practical steps you can take to move from paper-based preparedness to operational confidence. Because in a real incident, you don't rise to the level of your plan – you fall to the level of your training.

Why just having a plan isn't enough

Having an incident response or business continuity plan on paper is just the first step. In the heat of a crisis, theory often falls apart without practice. Plans that aren't regularly tested can quickly become outdated and misunderstood (or forgotten). Teams may be unclear on roles, communications may falter, and critical decisions may be delayed. True resilience comes from rehearsing scenarios, identifying weaknesses, and building muscle memory – so when an incident does happen, your response is coordinated, confident, and effective.

The basics of exercising

Cybersecurity exercises are essential tools for building, testing, validating, and continuously improving cybersecurity capabilities. They provide a safe and realistic environment to practise skills, techniques, tools, processes, plans, communications, and relationships. These exercises also help build valuable relationships between individuals and institutions that need to work together to mitigate cyber risks.

According to the UK Government, which has made exercising a legal requirement for certain organisations, planning cannot be considered reliable until it is exercised and has proved to be workable. False confidence may be placed in the integrity of a written plan if it is not tested, as the assumptions which are a necessary element of an initial plan will not be appropriately scrutinised by the individuals with nominated roles and responsibilities.

The UK Government's guidance emphasises that participants in exercises should be aware of their roles and comfortable with them before facing the stresses of an exercise. The aim is to test procedures, not catch people out. If staff are under-prepared, they may blame the plan when they should blame their lack of preparation and training.

Exercises in general aim to:

- Validate plans (Validation).
- Develop staff competencies and give them practice in their roles (Training).
- Test well-established procedures (Testing).

Objectives describe the conditions under which the exercise is conducted and the desired end state. For example, a Tabletop Exercise might aim to:

- Validate a country, sector, or organisation's capability and plans to defend against and respond to high-impact cybersecurity risks.
- Test the effectiveness of crisis management frameworks.
- Ensure interoperability of plans among organisations managing cyber risks.
- Test crisis communications, including media and social media usage.
- Revalidate and improve plans in light of new developments.
- Familiarise and train senior executives, managers, and teams with their roles and responsibilities.
- Practise and test established procedures, including internal, external, and social media communications.

Exercises can be run at various levels:

- **International:** Involving organisations from multiple countries, including multi-lateral or bi-lateral exercises.
- **National:** Involving elements of national infrastructure, particularly Critical National Infrastructure (CNI), government, major industrial, commercial, and financial systems.
- **Sectoral:** Involving elements of a CNI sector, industry, commercial sector, government departments, or other groups with shared interests.
- **Organisational:** Involving a single organisation with a common security boundary.

Exercises may include various elements of an incident command structure:

- **Gold/Strategic:** Defining incident response strategy and crisis management.
- **Silver/Tactical:** Maintaining situational awareness and translating the incident response strategy into actionable priorities for operational responders.
- **Bronze/Operational:** Hands-on incident response and fulfilling tactical priorities.

Types of exercises:

- **Tabletop exercises** simulate a realistic scenario and timeline, allowing teams to practise and test communications, information flows, operational processes, and decision-making. They do not involve staging a mock incident or creating a technical environment. These exercises are useful for validating plans and exploring weaknesses.
- **Discussion-based or Scenario-driven workshops** engage stakeholders in strategic discussions through a step-by-step risk scenario. These workshops are quick ways to assess options and plans for new threats or vulnerabilities, useful for training and awareness.
- **Technical exercises** allow technical teams to practise and test their skills in a realistic cybersecurity scenario with simulated infrastructure and challenges.
- **Live-Play exercises** provide a live rehearsal for full plan implementation, testing decision-making, technical skills, and information flows at all levels. These exercises involve external partners and are useful for verification, validation, and experiential learning.

Frequency of exercises

Best practice recommends exercising incident response and business continuity plans at least annually, or following major changes (e.g., new systems, staff turnover), with more frequent, scenario-specific drills for high-risk areas. Ideally, you should run a mix of exercise types throughout the year. However, many struggle to maintain this cadence due to resource constraints, competing priorities, or a false sense of readiness. The result is a fragmented or outdated response capability. Precisely when a coordinated, practiced reaction is most needed.

The key elements of a cybersecurity exercise

Timetable

A Tabletop Exercise typically lasts for one working day, allowing time for the scenario to develop, participants to discuss and assess their responses, and a 'hot debrief' to close the session. If organisations run a shift system, the exercise may extend over two days to rehearse shift handovers, agreed during the scoping phase.

Participants

Participants are agreed during the scoping phase based on the exercise's purpose and objectives. Exercises typically involve senior managers, operational managers, and technical experts. Senior managers focus on directing cybersecurity capabilities and responding to cyber-attacks, supported by operational managers and technical experts who handle events and decisions. Exercises at the organisational level may include more junior staff where a learning environment is desirable to enable knowledge transfer.



Exercise Team

An example **Exercise Design Team** may include the following roles:

- **Exercise Design Lead** manages relationships with participating teams and organisations and directs the exercise design.
- **Scenario Design Lead** manages scenario production and the Main Events List (MEL).
- **Evaluation Lead** identifies metrics and develops the Performance Evaluation Log (PEL).

Additional roles may include:

- **Scenario Subject Matter Experts (SMEs)** provide expertise on threat actors, vulnerabilities, and expected actions.
- **Design Team SMEs** experts appointed by the Design Team for authenticity and complexity.
- **Participant SMEs** experts from participating teams or organisations who ensure realism and relevance.
Exercise Project Manager ensures progress and manages external requirements.
- **Administrative Support Staff** may include audio-visual specialists or graphic designers.

An example **Exercise Delivery Team** may include:

- **Exercise Director** runs the exercise and coordinates the team.
- **Exercise Controller** delivers information on events using the MEL.
- **Exercise Observer** records decisions and actions, evaluates performance, and identifies issues.

Additional roles may include:

- **Scenario SMEs** who advise on running the MEL and support the Exercise Observer.
- **Participant SMEs** can help maintain realism and assess performance.
- **Project Manager and Support Staff**, such as secretariat, administrative, IT, audio-visual, or logistics staff.

A note on team membership overlap:

The Exercise Delivery Team often includes members from the Exercise Design Team to ensure continuity and understanding of the scenario, objectives, and evaluation criteria.

Scenario

Once the purpose, objectives, and scope of an exercise are agreed, the next step is to develop a realistic scenario supported by events that will trigger planned decisions and actions. The scenario should be up-to-date and relevant to participants' operations and infrastructure, reflecting recent threats and attackers' methods. It should test participants' capabilities thoroughly but not overwhelm them, ensuring they feel challenged yet confident.

Performance Evaluation Log (PEL)

Expected actions should be based on mandatory requirements or best practice, including laws, regulations, policies, and skills. The need to test conformity with these standards is covered in scoping discussions and elaborated with evaluation criteria identified by SMEs. The Exercise Observer maintains the PEL, listing expected actions and applicable criteria, such as timing. In Tabletop Exercises, the Observer may rely on participants stating what they 'would do'.

Main Events List (MEL)

In a Tabletop Exercise, events requiring decisions or actions are delivered by the Exercise Controller as 'information injects'. These are documented in the MEL to ensure they are given in the correct order and at the right time. Injects may include written questions or be asked aloud by the Exercise Director.

Evaluation

A hot-debrief should be conducted immediately after the exercise has concluded to gather initial observations and thoughts. The hot-debrief looks to summarise what went well, what could be improved, and to provide opportunity for feedback and questions from participants. A senior figure within the Exercise Delivery Team, should request, collect, assess, and analyse participant feedback responses to support production of an evaluation report. The report is completed and circulated within two weeks of the exercise concluding, while experiences are fresh.

It is good practice to meet with exercise participants for a cold debrief and to discuss the findings. This meeting also provides opportunity to nominate action owners, ensuring that any risks that have been identified are tracked through to remediation. Recommendations for further action are usually made for reviews of plans, policies, procedures, or training requirements.

A post exercise evaluation conducted in parallel can also be useful in some circumstances to provide an opportunity for facilitators to discuss design issues raised and focus on measures to address them. This ensures lessons on exercise design and delivery are learned and processes are continually improved.

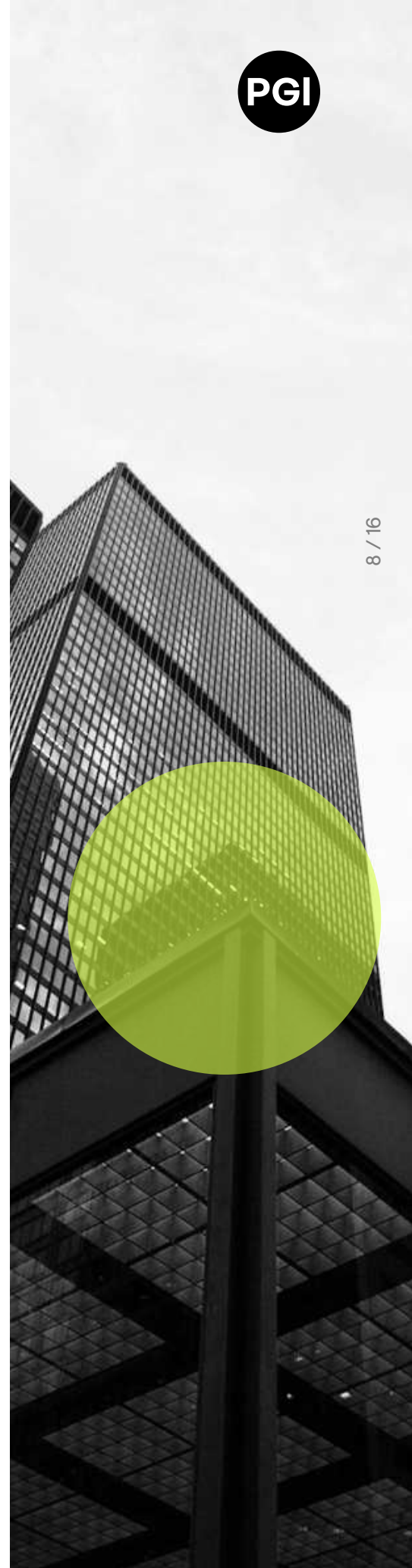
The business case for exercising

Investing in incident response and business continuity exercises delivers tangible value far beyond compliance. At a time when cyberattacks can halt operations, erode customer trust, and invite regulatory scrutiny, a well-rehearsed response can significantly reduce downtime, costs, and reputational damage.

Exercising reveals hidden vulnerabilities—from outdated contact lists to unclear escalation paths—before they become critical failures. It also strengthens internal coordination, sharpens decision-making, and builds confidence across teams and leadership. For boards and stakeholders, evidence of regular exercising demonstrates operational maturity and commitment to resilience.

Increasingly, **regulators and insurers expect more than written plans**; they want proof of practice. In some cases, insurers may reduce premiums for organisations that can show a history of regular testing and improvement.

Far from being a cost centre, **exercising is a proactive, measurable way to protect your business, reduce risk exposure, and enhance your response readiness in a world where every second counts**. Importantly, it is more cost-effective to discover vulnerabilities and make mistakes during an exercise than to be exposed during a real incident.



Common pitfalls and how to avoid them

Despite the obvious benefits, many organisations fall into predictable traps when it comes to incident response and business continuity exercising. A common mistake is treating exercises as a one-off or tick-box activity — running a single tabletop session and assuming the job is done. True resilience requires regular practice, iteration, and learning; exercises should be integrated into a feedback loop that supports broader continuous improvement efforts.

Another pitfall is failing to involve the right stakeholders. Cyber incidents don't just affect IT — legal, communications, HR, and senior leadership all play crucial roles in managing impacts. Exercises that exclude these voices risk leaving coordination gaps when it matters most.

Some teams also make exercises too narrow or unrealistic, avoiding difficult scenarios or sanitising outcomes. While it's tempting to play it safe, the most valuable insights often come from uncomfortable 'what ifs' that push assumptions and expose weak points.

To get the most from exercises, organisations should take a structured, inclusive, and honest approach — one that values learning over perfection and embeds continuous improvement into crisis preparedness.



Example Tabletop Exercise: Widespread vendor outage

It is recommended that the following scenario, timeline, and injects—inspired by a real-world event—are reviewed and updated to suit your exact requirements and exercise objectives. Incident response challenges, discussion points and technical environments should also be considered before delivering to participants.

This exercise has been designed for a 5-hour session, during which, you will simulate an IT outage that lasts several days, starting on Friday morning. The session should include time for a hot debrief once the exercise has concluded. It is suggested that appropriate breaks be considered for addition into the timetable.

Exercise Facilitator Pack

Scenario briefing

Your organisation uses a widely deployed endpoint security tool from a global vendor. Early in the morning, devices across your estate begin crashing after a vendor update is pushed automatically. The vendor posts a brief notice on social media acknowledging “a widespread issue” affecting users globally. Internal staff are concerned of a cyber attack, but little information is currently known about the situation.

Relevant sectors

- Public Sector
- Corporate Enterprises
- Healthcare
- Education
- Critical National Infrastructure

Suggested participants

- Chief Information Officer (CIO) or IT Director
- IT Operations Lead / Infrastructure Manager
- Incident Response Manager or Head of Cybersecurity
- Service Desk / IT Support Manager
- Business Continuity Manager
- Risk and Compliance Manager
- Internal Communications or Comms Manager

Tailoring guidance

- Public Sector: Highlight reliance on centralised IT services across multiple agencies.
- Healthcare: Emphasise risks to clinical systems and patient safety.
- CNI: Focus on operational technology disruptions.

Indicative inject timetable

Introduction

Start + 0 mins

Introduce facilitators and participants. Introduce agenda. Introduce scenario.

Inject 2

Start + 1 hr

IT suspects vendor update caused failure

Inject 4

Start + 2.0 hrs

Your senior leadership team requests impact assessment and options

Inject 1

Start + 30 mins

Users report Blue Screens of Death

Inject 3

Start + 1.5 hrs

Vendor releases initial status message via social media

Suggested Break

Inject 5

Start + 2.5 hrs

Media headlines refer to "global cyber meltdown"

Inject 6

Start + 3.0 hrs

Some departments move to pen-and-paper workarounds

Inject 7

Start + 3.5 hrs

Vendor posts hotfix instructions

Inject 8

Start + 4.0 hrs

Post incident review

Hot debrief

Start + 4.5 hrs

Summarise observations including strengths, weaknesses and areas for improvement. Participant questions. Next Steps.

Indicative success criteria (Performance Evaluation Log)

- Timely identification of the root cause and scope of impact, with effective engagement of external vendors.
- Clear activation of incident management roles and structure, ensuring decisive leadership and coordination.
- Prioritised, staged recovery plan was developed and implemented safely, minimising further disruption.
- Effective internal communication, ensuring staff were informed and supported with status updates and workarounds.
- Business continuity plans were followed or adapted effectively, enabling critical functions to continue during the outage.
- Demonstrated integration of BC and cyber plans.

Scenario briefing

Early on Friday morning, devices across your estate begin crashing causing significant disruption across the business. Rumours of a cyber-attack and ransomware quickly spread amongst staff.

EXERCISE INJECTS

Users are reporting that their devices are showing Blue Screens of Death (BSOD) and they are unable to perform their critical tasks.

Friday, 09:00

Discussion questions:

- How do users report issues?
- What is your immediate technical and business response – is your escalation pathway documented?
- How do you determine the scale of the impact?
- Is this a declared incident
- What do you tell staff?

The vendor posts an initial status message via social media: “We are actively working with customers impacted by a defect found in a single content update for Windows hosts. Mac and Linux hosts are not impacted. This is not a security incident or cyberattack.

Friday, 12:00

Discussion questions:

- How do you verify vendor messaging?
- What do you tell your internal stakeholders?

Your IT team suspects that a software update issued by a third-party security vendor has caused the failure but they can't yet confirm the root cause.

Friday, 10:00

Discussion questions:

- What analysis needs to take place?
- Do you remove the update or wait for the vendor?
- Who makes this decision?
- How do you coordinate across IT and business teams?

Hearing that customer services and finance operations have been significantly affected, the senior leadership team requests an impact assessment and asks for options.

Friday, 12:15

Discussion questions:

- How is an impact assessment conducted, by whom?
- What are your top 3 response options?
- How do you explain technical risks to non-technical leaders?

Media headlines refer to “global cyber meltdown” and your organisation is approached for comment.

Friday, 13:15

Discussion questions:

- How do you manage reputational risk?
- Who is responsible for media interviews and are they trained to perform this role?
- What internal and external comms do you issue?
- Who is responsible and accountable for issuing communications?

The software vendor posts hotfix instructions online, but due to the nature of the incident, the endpoints can't be restored remotely. Confidence in the fix is low, and the active cybersecurity protections provided by the vendor are questioned by technical staff. IT indicate that it could take days to restore all Windows endpoints.

Saturday: 09:00

Discussion questions:

- Do you apply the hotfix immediately or test it first?
- How do you support decentralised teams with recovery?
- How would IT prioritise what gets restored first?
- How is weekend working and overtime managed?

Due to the ongoing disruption, some departments move to pen-and-paper workarounds.

Friday, 13:30

Discussion questions:

- Do your business continuity plans work in this scenario?
- How long can these workarounds be maintained?
- When did the organisation last conduct a business impact analysis?

As systems begin to stabilise, the senior leadership team asks for a post-incident review. They want to understand the broader business, legal, reputational, and operational impacts of the outage, including any remaining risks. There's also interest in whether the organisation should change how it selects, validates, or relies on critical third-party software vendors.

Monday, 15:00

Discussion questions:

- When is the incident closed?
- How is the post incident review conducted and who is responsible for coordinating activity?
- What long-term actions or reviews should be triggered after this incident?
- Is the third-party risk management strategy effective?

Preparedness is a team sport

Cyber resilience isn't built on policies alone — it's established through practice, collaboration, and continuous improvement. Incident response and business continuity planning are only effective when they're understood, tested, and rehearsed across the business. From IT and legal to HR and executive leadership, everyone has a role to play in a crisis.

Exercising your plans turns theory into action. It helps clarify responsibilities, improve communication, and uncover gaps before they become business-critical. It also builds confidence — within teams, and with clients, regulators, and insurers.

In an era where digital threats are constant and consequences are immediate, preparedness is no longer optional. Organisations that invest in regular, realistic exercising will not only respond better — they'll recover faster and emerge stronger.

At PGI, we specialise in helping our clients achieve digital resilience, and we integrate cyber security exercises into our offer of testing and improving organisational risk management procedures. We ensure team-based learning outcomes within our training programmes.

Our exercise team consists of individuals with over 20 years' experience of strategic, operational, tactical level exercises, and skills in building and using the most up to date technical exercise environments.

We regularly develop and implement tabletop and technical exercising as part of our training and capacity building programmes. We have built and operated technical courses aligned with those of CREST and other certifying bodies as part of our end of course exams.

We have been employed by the UK and other government departments to develop and run technical and tabletop cyber security exercises. We've done this for national and multinational audience covering sectors from oil and gas to law enforcement.

If you would like to talk about how we can support you with the testing of your Incident Response and Business Continuity plans, contact us.

Glossary

APT (Advanced Persistent Threat): Sophisticated malware covertly installed on a network with malicious intent by an attacker.

CTI (Cyber Threat Intelligence): Information about threats and threat actors that helps organisations prevent or mitigate cyber-attacks.

Cold debrief: Structured review conducted after the exercise concludes, allowing for reflection, analysis, and incorporation of additional evidence such as logs, timelines, and observations. Focuses on lessons identified, systemic issues, and actionable improvements. May involve a wider audience than the hot debrief.

Exercise: A single, or series of, scenarios that allow participants to practise the realistic response to an event or incident, delivered in a safe environment to allow learning and development.

Exercise Controller, Control, Director: Roles responsible for managing and facilitating the exercise, ensuring it runs smoothly and objectives are met.

Hot debrief: Rapid summary of initial conclusions, observations, and feedback from participants immediately after the exercise concludes. May also be known as a 'wash up' or 'hot wash up.'

Inject: A section within a scenario that provides new or further information on an event or activity to develop the scenario.

MEL (Main Events List): A detailed list of events and injects that guide the flow of the exercise, ensuring participants receive information in the correct order and at the right time.

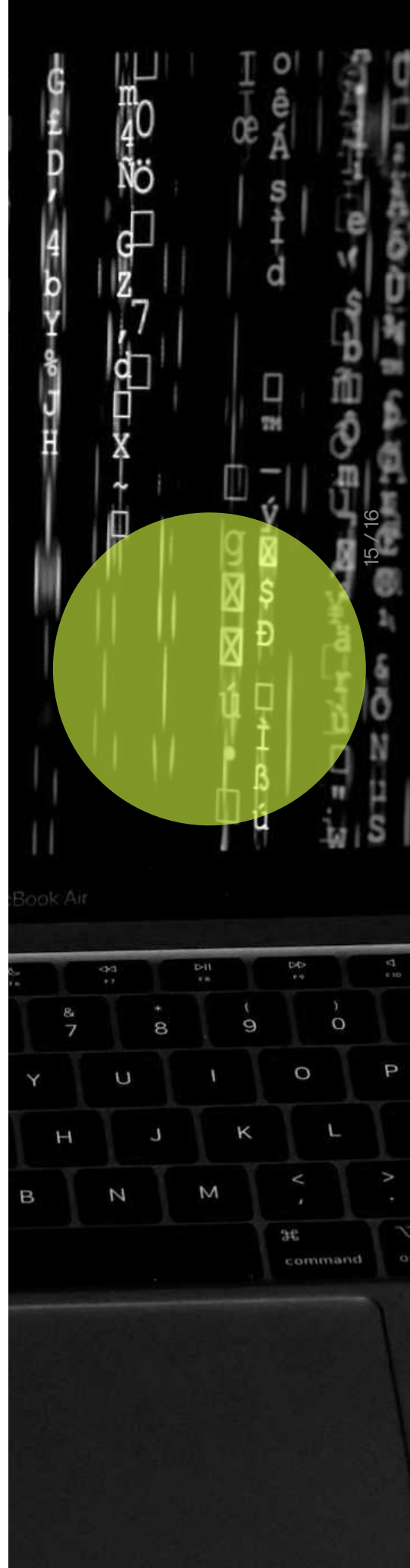
Participant / Participating Organisation: Individual or organisation being exercised.

PEL (Performance Evaluation Log): A log used to record and evaluate participants' actions and decisions during the exercise, based on predefined criteria.

POC (Point of Contact): A single individual who acts as the focal point for all issues and enquiries and ensures they are addressed.

Scenario: A detailed and realistic narrative used to guide the exercise, including events and conditions that participants must respond to.

SME (Subject Matter Expert): An expert in a specific area who provides knowledge and expertise to inform the exercise.



We specialise in helping our clients achieve digital resilience, and we integrate cyber security exercises into our offer of testing and improving organisational risk management procedures. We ensure team-based learning outcomes within our engagements.

We are an NCSC Assured Cyber Incident Exercise service provider. This means that we meet the National Cyber Security Centre's rigorous standards for high quality cyber incident exercising.



Find out more at www.pgitl.com